STRICTLY CONFIDENTIAL

Muscle Mentors Academy — Security Audit Report

COMPREHENSIVE VULNERABILITY REVIEW & PAYMENT GATEWAY RISK ASSESSMENT

Date: 30 October 2026
Target: musclementorsacademy.com
Repo: makeoptivus-cmd/musclementor

⚠️ Executive Notice: Compromised Production Secret Key

A LIVE Razorpay Key Secret is hardcoded in plaintext within the repository codebase (`server/server.js` and `server/.env.example`). This credential must be treated as actively compromised. Immediate rotation in the Razorpay Dashboard is required to prevent unauthorized account manipulation or refund exploitation.

CRITICAL SEVERITY
1 Issue
Leaked Live Razorpay Secret

HIGH SEVERITY
3 Issues
Price Tampering, Data Misuse, Fake Flow

MEDIUM SEVERITY
2 Issues
DoS / No Rate Limit, Open CORS

LOW / ADVISORY
2 Issues
Plaintext Logging, Phishing Brand Risk

Summary of Findings & Remediation Matrix

#	Vulnerability & Security Risk	Severity	Affected Component	Recommended Remediation
1	LIVE Razorpay Secret Key exposed in source code	CRITICAL	`server/server.js`, `.env.example`	Regenerate key in Razorpay dashboard; store in ENV only
2	Customer contact & transaction data misuse risk	HIGH	Razorpay API / Customer Data	Audit access logs; restrict API scopes; enforce staff 2FA
3	Fake payment flow & client-side success screen	HIGH	`payment.html`, `js/main.js`	Enforce server-to-server verification & Razorpay webhooks
4	Unauthenticated order creation & client-controlled amount	HIGH	`/api/razorpay/create-order`	Define official course price catalog on backend
5	Server/API abuse & Denial-of-Service (No rate limit)	MEDIUM	`server.js` (Express Router)	Add `express-rate-limit` (10 requests/15 mins)
6	CORS allows arbitrary website origins with credentials	MEDIUM	`server.js` (CORS policy)	Restrict origin to `musclementorsacademy.com`
7	Sensitive customer and payment details written to logs	LOW	`server.js` (Console logging)	Sanitize logs; mask customer phone numbers & emails
8	Website brand impersonation & phishing risk	ADVISORY	Domain & Brand Reputation	Configure SPF, DKIM, DMARC; display official security notice

FINDINGS 1 TO 4

Critical & High Severity Findings

Scope: Backend Server & Payment Flow

AUTHENTICATION, DATA PROTECTION, AND PAYMENT VERIFICATION RISKS

1. LIVE Razorpay Credential Exposed in Public Source Files

CRITICAL SEVERITY

WHAT IS THE ISSUE?

The website repository contains the active **Live Key ID** and **Live Key Secret** directly inside source and documentation files. Anyone viewing the repository can read the secret without any technical skills.

LOCATION EVIDENCE:

```
server/server.js (Line 83): keySecret = 'z3hbpqpvKC2XyWolIPkSSKJ9'
server/.env.example (Line 2): RAZORPAY_KEY_SECRET=z3hbpqpvKC2XyWol...
```

WHAT COULD HAPPEN?

An unauthorized entity can sign in directly to Razorpay's API as the merchant, fetch full customer payment records, issue arbitrary refunds to drain the account balance, or view linked bank accounts.

IMPACT ASSESSMENT:

High company impact: unauthorized account activity, financial loss, reconciliation overhead, and compromise of customer trust.

2. Customer Information Could Be Misused (Social Engineering & Scams)

HIGH SEVERITY

WHAT IS THE ISSUE?

The Razorpay account holds student names, phone numbers, email addresses, and course enrollment amounts. If exposed via the API key, this data can be harvested in bulk.

POTENTIAL EXPLOITATION:

Scammers can target students using their exact enrollment info (e.g. "*Your ₹10,000 payment for Strength Training Fundamentals failed. Click here to refund*"), leading to WhatsApp OTP fraud and phone spam.

3. Client-Side Payment Verification & Weak Fulfillment Validation

HIGH SEVERITY

WHAT IS THE ISSUE?

The website can display a success confirmation based purely on the client-side JavaScript callback. The backend signature check validates HMAC, but does not verify with Razorpay whether the payment status is actually captured for the correct amount.

POTENTIAL EXPLOITATION:

If a downstream enrollment process or course portal relies on browser feedback rather than server confirmation, fraudulent or canceled orders could be granted course access.

4. Unauthenticated Order Creation & Caller-Controlled Pricing

HIGH SEVERITY

WHAT IS THE ISSUE?

`POST /api/razorpay/create-order` accepts any `amount` passed in the request body. It only checks `amount >= 100` (₹1.00) without matching against official course fees.

POTENTIAL EXPLOITATION:

A visitor can modify the JSON payload in their browser to pay ₹1.00 for a ₹30,000 Bodybuilding course. Razorpay legitimately captures ₹1.00, generating a valid signature and success message.

FINDINGS 5 TO 8

Medium Severity & Operational Risks

Scope: Infrastructure & External Threat Vectors

AVAILABILITY, ORIGIN CONTROLS, LOGGING HYGIENE, AND BRAND PROTECTION

5. Server/API Abuse Could Slow or Crash the Website (No Rate Limiting)

MEDIUM SEVERITY

WHAT IS THE ISSUE?

The order creation endpoint has no request throttling. Each request causes the Node.js server to initiate an external HTTPS call to Razorpay.

POTENTIAL EXPLOITATION:

An automated script sending hundreds of requests will exhaust cPanel CPU/RAM limits or trigger Razorpay API rate throttling, locking out legitimate students during checkout.

6. Overly Permissive CORS Configuration Allows Arbitrary Origins

MEDIUM SEVERITY

WHAT IS THE ISSUE?

In `server/server.js` lines 58-62, the CORS callback executes `callback(null, true)` for all origins outside the approved domain list, combined with `credentials: true`.

POTENTIAL EXPLOITATION:

Arbitrary websites can make browser-based cross-origin calls to the backend API, bypassing intended origin restrictions.

7. Sensitive Information Written to Application Console Logs

LOW SEVERITY

WHAT IS THE ISSUE?

The backend logs full request payloads including `amount`, `notes` (student course plans), and full error payloads directly into stdout console logs.

POTENTIAL EXPLOITATION:

If hosting logs are stored insecurely or accessible to third-party hosting technicians, customer and order details could be viewed unintentionally.

8. Website Impersonation & Phishing Website Risk

ADVISORY / GENERAL

WHAT IS THE ISSUE?

Public branding assets, certificates, and course curriculum could be duplicated by malicious third parties onto lookalike domains (e.g. `musclementors-academy.in`).

PREVENTATIVE ACTION:

Implement email sender authentication (SPF, DKIM, DMARC) for `musclementorsacademy.com` and advise students to pay only via the verified domain.

CODE REMEDIATION

Technical Remediation & Ready Code Patches

File: server/server.js

COMPLETE IMPLEMENTATION CODE TO HARDEN THE EXPRESS BACKEND

Patch 1: Secure Credential Loading (Eliminating Plaintext Fallbacks)

```
// Load from Environment Variables only (never use hardcoded fallbacks in source code)
const keyId = process.env.RAZORPAY_KEY_ID;
const keySecret = process.env.RAZORPAY_KEY_SECRET;

if (!keyId || !keySecret) {
  console.error('[FATAL] Missing RAZORPAY_KEY_ID or RAZORPAY_KEY_SECRET in environment.');
  process.exit(1);
}
```

Patch 2: Server-Side Price Catalog & Rate Limiting

```
const rateLimit = require('express-rate-limit');

// Rate Limiter: Max 10 order creations per 15 minutes per IP address
const orderLimiter = rateLimit({
  windowMs: 15 * 60 * 1000,
  max: 10,
  message: { error: 'Too many order attempts. Please try again after 15 minutes.' }
});

// Official Server-Side Price Catalog (In Paise: 1 INR = 100 Paise)
const OFFICIAL_PRICES = {
  'strength-fundamentals': { name: 'Strength Training Fundamentals', price: 1000000 }, // ₹10,000
  'diet-nutrition': { name: 'Diet & Nutrition', price: 600000 },                       // ₹6,000
  'cpr-practical': { name: 'CPR - Practical', price: 300000 },                         // ₹3,000
  'bodybuilding-contest': { name: 'Bodybuilding Contest Preparation', price: 1500000 },  // ₹15,000
  'weight-loss': { name: 'Weight Loss Management', price: 600000 },                    // ₹6,000
  'disease-management': { name: 'Disease & Disorder Management', price: 800000 },      // ₹8,000
  'injury-prevention': { name: 'Injury Prevention', price: 800000 }                    // ₹8,000
};

// Secure Order Endpoint: Never trust client-supplied amount
app.post('/api/razorpay/create-order', orderLimiter, async (req, res) => {
  try {
    const { courseId, studentName, studentEmail, studentPhone } = req.body || {};
    const course = OFFICIAL_PRICES[courseId];
    if (!course) return res.status(400).json({ error: 'Invalid or missing course selection.' });

    const order = await razorpay.orders.create({
      amount: course.price, // Price determined strictly on the server
      currency: 'INR',
      receipt: `rcpt_${Date.now()}`,
      notes: { plan: course.name, studentName, studentEmail, studentPhone }
    });
    return res.json(order);
  } catch (err) {
    res.status(500).json({ error: 'Failed to create payment order.' });
  }
});
```

Patch 3: Strict Production CORS Whitelist

```
const allowedOrigins = [
  'https://musclementorsacademy.com',
  'https://www.musclementorsacademy.com'
];

app.use(cors({
  origin: function (origin, callback) {
    // Block any unauthorized cross-origin browser requests
    if (!origin || allowedOrigins.includes(origin)) return callback(null, true);
    return callback(new Error('Cross-Origin Request Blocked by Security Policy'));
  },
  credentials: true
}));
```

SECURITY ROADMAP

Prioritized Remediation Roadmap & Sign-Off

Target SLA: Full Resolution in 72h

STRUCTURED TIMELINE AND DEPLOYMENT VERIFICATION CHECKLIST

Priority Implementation Schedule

Priority	Required Remediation Task	Affected Files	Target Completion	Verification Method
P0 - URGENT	Regenerate Razorpay Key Secret in Dashboard; remove hardcoded secret from all codebase files	`server.js`, `.env.example`	Immediate (Today)	Verify API rejects old key; tests pass with new key
P1 - HIGH	Implement server-side course price catalog to prevent client amount tampering	`server/server.js`	Within 24 Hours	Send altered amount via curl; verify server enforces catalog price
P1 - HIGH	Lock CORS policy strictly to `https://musclementorsacademy.com`	`server/server.js`	Within 24 Hours	Test request from third-party domain; verify blocked
P2 - MEDIUM	Install `express-rate-limit` to protect order creation API from bot spam	`server/package.json`	Within 48 Hours	Trigger 15 rapid requests; verify 429 status code returned
P2 - MEDIUM	Implement Razorpay Webhook endpoint (`/api/razorpay/webhook`)	`server.js`	Within 72 Hours	Simulate webhook in Razorpay test mode; verify database record
P3 - LOW	Compress or remove 15MB raw photos and PDFs from public repository	Root Directory	Next Release	Lighthouse audit; mobile load speed < 2 seconds
P3 - LOW	Configure Cloudflare proxy DNS and DDoS protection	DNS & Cloudflare	Next Release	Verify DNS proxied; SSL certificate active

Deployment Security Sign-Off Protocol

Checkpoint	Description	Sign-Off Status
Credential Hygiene	No API secrets present in public Git history or client-side files	Pending Key Rotation
Payment Integrity	All monetary transactions strictly validated server-to-server	Pending Patch Deployment
DDoS & Availability	Rate limiting active on all API endpoints; CDN caching static assets	Pending Cloudflare Setup
Data Privacy	Customer contact details masked in logs; no public exposure	Pending Log Sanitization

Auditor Statement: This security review reflects the state of the codebase as of October 30, 2026. Applying the remediation patches detailed in this report will resolve the identified vulnerabilities, protect student customer data, prevent revenue leakage, and safeguard the academy's brand reputation.